

Outside-In Certificate Risk Assessment

A real-world-informed assessment redesigned as a synthetic enterprise dataset. Names, domains, IP addresses, dates, geography, counts, and evidence rows have been altered while realistic security relationships and analytical meaning are retained.

REAL-WORLD-INFORMED SYNTHETIC DATASET | ILLUSTRATIVE ENTERPRISE

Prepared by Vellitas, LLC

September 2026

CONFIDENTIAL - DESIGN PROTOTYPE - NOT A FRESH SECURITY ASSESSMENT

EXECUTIVE VIEW

The exposed certificate estate contains material, externally observable risk.

This syntheticized portfolio demonstrates discovery, enrichment, policy comparison, prioritization, and corrective guidance at global scale. Metrics were altered to prevent attribution while preserving plausible cross-category relationships.

CERTIFICATES DISCOVERED

38,640

Internet-visible certificates associated with approved markers.

WEAK PROTOCOLS

8,912

Hosts presenting legacy encryption protocols.

SELF-SIGNED

6,284

Certificates without third-party trust validation.

WEAK SIGNING

9,476

24.5% used SHA-1 or weaker algorithms.

ACTION REQUIRED

Executive conclusion

The portfolio requires a coordinated remediation program, not isolated certificate replacement. First establish ownership and business need, then correct cryptographic defects, retire forgotten endpoints, and verify each change from the outside. Geographic and name anomalies require customer validation before they are treated as compromise.

OBSERVED FROM THE OUTSIDE

What the real-world-informed model demonstrates.

The report documents a repeatable process that starts with approved customer markers and ends with prioritized evidence and recommended corrective work.

01

Discover

Search internet-visible certificate deployments associated with domains, names, IP ranges, and other approved identifiers.

02

Enrich

Attach IP, country, certificate authority, serial number, signature algorithm, validity, key strength, and presented protocol.

03

Compare

Evaluate observed issuance, location, lifetime, environment markers, protocol, cipher, and certificate properties against expectations.

04

Prioritize

Surface anomalous geography, name encroachment, self-signed, expired, near-expiry, weak-key, weak-signature, wildcard, and non-production exposure.

05

Recommend

Provide corrective actions, ownership questions, revocation or renewal guidance, and a focused evidence appendix.

OBSERVATION BOUNDARY

The report is based on public-facing certificate and TLS evidence. It does not prove ownership, internal configuration, compromise, or business legitimacy without customer confirmation and separately authorized investigation.

PRIORITIZED PORTFOLIO

Observed conditions, ranked for investigation.

Counts may overlap because one certificate can present multiple conditions. Severity should be calibrated using asset criticality, customer policy, and corroborating evidence.

Weak signing algorithm	9,476		IMMEDIATE
Weak encryption protocol	8,912		IMMEDIATE
Weak key (<2048-bit)	7,305		IMMEDIATE
Self-signed certificate	6,284		INVESTIGATE
Wildcard certificate	5,842		REVIEW
Non-production marker	4,116		INVESTIGATE
Expiring within 90 days	2,893		PLAN
Expired certificate	683		IMMEDIATE

Interpretation

The syntheticized portfolio models 6.8% weak cipher-suite use and a multi-authority issuance profile. The report separates observed facts from investigative hypotheses and assigns validation before remediation.

LOCATION IS CONTEXT, NOT PROOF.

This illustrative distribution demonstrates country-level geospatial enrichment and flags locations outside the expected operating pattern for customer review.



CUSTOMER VALIDATION REQUIRED

Investigation rule

A new or unusual country raises priority only when it conflicts with customer expectations or is corroborated by certificate, DNS, ASN, provider, issuer, naming, or historical evidence. Cloud delivery, CDNs, outsourcing, disaster recovery, and acquisitions can all create legitimate geographic changes.

NAMES THAT RESEMBLE THE ORGANIZATION DESERVE REVIEW.

This syntheticized assessment demonstrates organization-name, domain, and proximal-name discovery across internet-visible certificates.

CANDIDATE 01

typo-brand.example

Observed naming: Certificate text used a one-character variation of the enterprise name

Working interpretation: Possible character substitution or unrelated naming.

CANDIDATE 02

weather-provider.example

Observed naming: mobile-brand.weather-provider.example

Working interpretation: Possible authorized third-party service.

CANDIDATE 03

managed-service.example

Observed naming: DDN_GlobalEnterprise_IBW.managed-service.example

Working interpretation: Possible outsourcing or technology partner.

DO NOT INFER COMPROMISE FROM SIMILARITY ALONE

Required decision path

Confirm whether the domain and certificate belong to the customer, an approved vendor, an unrelated organization, or a deceptive actor. Approved dependencies should be added to the governed inventory. Suspicious issuance should be investigated with the issuer and, when justified, revoked or reported through the appropriate process.

CERTIFICATE AUTHORITY AND SELF-SIGNED EXPOSURE.

The syntheticized dataset inventories issuer families and distinguishes public trust from self-signed certificate deployments.

ISSUER FAMILIES

14

Public, private, and self-signed trust patterns.

PUBLIC CA FAMILIES

10

Illustrative portfolio count.

SELF-SIGNED

6,284

Requires ownership and purpose review.

Current analytical value

Unexpected issuers, inconsistent trust patterns, and large self-signed populations can identify policy drift, default appliance certificates, unmanaged services, or incorrect ownership assumptions.

Required customer context

Self-signed does not automatically mean malicious. Private appliances, lab systems, and controlled service-to-service uses may be legitimate, but public exposure still requires validation and policy alignment.

EVIDENCE BEFORE CONCLUSION

Modern reporting treatment

Record issuer, serial number, subject and SANs, validity, fingerprint, public-key hash, chain status, endpoint, observation time, and policy result. Tie each finding to an approved issuer list and a specific remediation or documented exception.

EXPIRATION AND VALIDITY REQUIRE OWNERSHIP DECISIONS.

The report demonstrates expired, near-expiry, and long-validity analysis using internally consistent syntheticized lifecycle buckets.

ALREADY EXPIRED

683

Immediate ownership and service-need decision.

EXPIRE IN 90 DAYS

2,893

Renew, replace, or decommission.

OVER 2 YEARS

1,942

Illustrative long-validity count.

VALIDATION BUILT IN

Validity distribution

The syntheticized portfolio contains 1,942 certificates with validity beyond two years, including 312 beyond five years and 46 beyond ten years. Production reports recalculate nested buckets from raw observations and prevent contradictory totals from entering executive decisioning.

If the service is required

Assign an owner, replace the certificate with an approved profile, confirm complete chain presentation, and establish renewal monitoring.

If the service is not required

Remove DNS, revoke the certificate where appropriate, decommission the service, and verify that the endpoint is no longer reachable.

WEAK CRYPTOGRAPHY IS KNOWN EXPLOITABLE EXPOSURE.

The assessment demonstrates key-strength, signature-algorithm, protocol, and cipher-suite evaluation. A finding is mapped to current policy; it is not presented as proof that exploitation occurred.

WEAK KEY

7,305

Certificates below the 2048-bit threshold.

WEAK SIGNATURE

9,476

SHA-1 or weaker in the illustrative portfolio.

WEAK CIPHERS

6.8%

Illustrative portfolio percentage.

Legacy protocols observed

8,912



IMMEDIATE

Modern interpretation

TLS 1.0 and TLS 1.1 are deprecated by IETF RFC 8996. NIST SP 800-52 Rev. 2 provides modern TLS configuration expectations for federal systems. Customer reports should map the exact observed protocol, cipher, key, signature, and chain evidence to the policy that applies to that environment.

Corrective work

Disable obsolete protocols and disallowed cipher suites, replace weak keys and signatures, deploy the complete approved chain, test compatibility, and reobserve the public endpoint after change. Where replacement creates operational risk, document an exception with compensating controls and a retirement date.

WILDCARD AND NON-PRODUCTION CERTIFICATES EXPAND OPERATIONAL RISK.

These conditions are not automatically vulnerabilities. They become higher priority when combined with unmanaged ownership, public exposure, weak configuration, expiry, excessive reuse, or policy drift.

WILDCARD CERTIFICATES

5,842

518 showed additional lifecycle risk.

NON-PRODUCTION MARKERS

4,116

Test, development, QA, staging, or similar names.

Wildcard review

Identify reuse across endpoints, confirm private-key custody, reduce blast radius, document legitimate coverage, and replace broad certificates where narrower SANs are practical.

Non-production review

Confirm whether the endpoint is intentionally public, hardened, patched, monitored, owned, and separated from production data and credentials.

ROADMAP STATUS UPDATED

Current feature confirmed

Historical assessment evidence confirms that Vellitas generated a special flag when certificate nomenclature indicated a non-production service. That places certificate-creep detection based on naming signals in the demonstrated current-capability baseline.

TURN FINDINGS INTO OWNED, TESTABLE WORK.

The modern report organizes findings and recommendations into a phased remediation program with explicit verification.

01

Validate scope and ownership

Reconcile domains, vendors, business owners, approved locations, issuers, and exception policy.

02

Contain immediate exposure

Address expired certificates, obsolete protocols, weak keys or signatures, and suspicious public non-production services.

03

Reduce structural risk

Rationalize certificate authorities, self-signed use, wildcard reuse, long validity, and unmanaged dependencies.

04

Verify from the outside

Reobserve each endpoint, record the corrected evidence, and preserve closure or exception rationale.

05

Continue monitoring

Repeat discovery and notify on material changes to the external security profile.

REPRESENTATIVE SYNTHETIC EVIDENCE.

Rows below preserve the structure and analytical usefulness of certificate evidence without reproducing a source customer's records. IP addresses use documentation-only ranges reserved for examples.

IP	Country	Signature	Authority	Expires	Years	Key	Protocol
192.0.2.34	USA	SHA-1	Self-signed	03/15/27	3.0	1024	TLS 1.0
198.51.100.72	Netherlands	MD5	Self-signed	11/30/26	10.0	1024	SSLv3
203.0.113.141	Singapore	SHA-1	Self-signed	06/30/26	5.0	1024	TLS 1.1

Capabilities confirmed by historical work

Internet-visible discovery; approved marker expansion; geospatial analysis; certificate authority inventory; name and domain encroachment; protocol and cipher analysis; self-signed, expiration, near-expiry, long-validity, weak-key, weak-signature, wildcard, and non-production detection; certificate-level evidence; portfolio summary; and consultant-authored remediation recommendations.

SOURCE CONTROL

This prototype is informed by patterns from a historical enterprise assessment. All names, domains, IP addresses, dates, geographic distributions, counts, and evidence rows have been altered or synthesized. Findings and proportions remain plausible demonstrations of Vellitas capabilities, but no row or metric describes the original customer or any current environment.